API SECURITY RISK ANALYSIS REPORT

Prepared by: **Aditya Goud**
CIN ID: **FIT/APR26/CS7516**
Internship: **Future Interns** - Cyber Security Program
API Tested: JSONPlaceholder (**jsonplaceholder.typicode.com**)
Date: April 2026
Tool Used: **Postman**

Introduction

What is API Security?

An API (Application Programming Interface) allows different software applications to communicate with each other. APIs power mobile apps, websites, dashboards and online services.

If APIs are not secured properly, attackers can:

- Access sensitive user data without permission
- Bypass authentication systems
- Overload servers with too many requests
- Access other users private information

API security testing is the process of identifying these weaknesses before attackers can exploit them.

Assessment Details:

API Tested : JSONPlaceholder
API URL : https://jsonplaceholder.typicode.com
Scan Type : Read-Only Analysis
Tool Used : Postman
Date : April 2026
Tested By : **Aditya Goud**
CIN ID : **FIT/APR26/CS7516**

Risk Classification:

🔴 High - Immediate action required
🟡 Medium - Should be fixed soon
🟢 Low - Fix when possible

Findings Summary:

No:	Vulnerability	Risk Level	Category
1	Unauthenticated Access to All users	🔴 High	Authentication
2	Excessive Data exposure	🔴 High	Data Exposure
3	Unauthorized Access to All Posts	🟡 Medium	Authorization
4	Missing Rate Limiting	🟡 Medium	API Abuse

Total Vulnerabilities Found: 4

🔴 High Risk : 2
🟡 Medium Risk : 2
🟢 Low Risk : 0

Methodology:

All tests were conducted using Postman with read-only GET requests on the public JSONPlaceholder test API. No exploitation or data manipulation was attempted. This analysis follows the OWASP API Security Top 10 guidelines.

Detailed Findings

1. Unauthenticated Access to All Users

Risk Level: 🔴 HIGH

Endpoint Tested: **GET https://jsonplaceholder.typicode.com/users**

Description:

The API allows anyone to access the complete list of all users without any login, API key or authentication token. No credentials are required to retrieve sensitive user information.

Data Exposed:

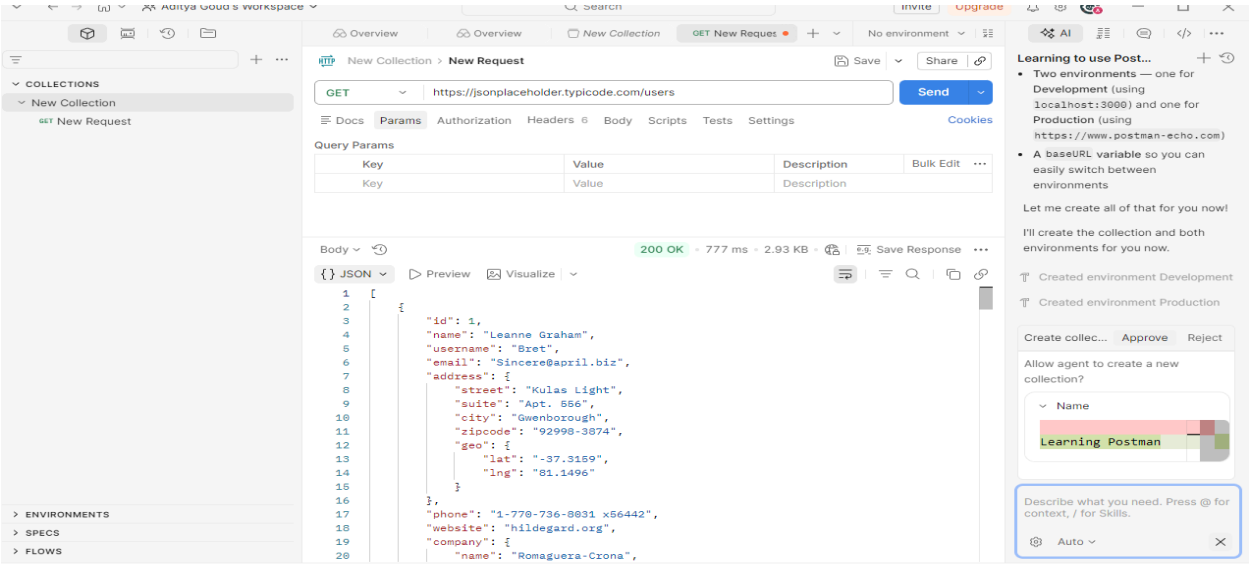
- Full name
- Email address
- Phone number
- Home address
- Company name
- Website URL

Business Impact:

Any attacker can harvest personal data of all users without any authentication. This can lead to identity theft, targeted phishing attacks and serious privacy violations.

Remediation:

Implement API authentication using API keys or JWT tokens. All user data endpoints must require valid authentication before returning any data.



2. Excessive Data Exposure

Risk Level: 🔴 HIGH

Endpoint Tested:**GET https://jsonplaceholder.typicode.com/users/1**

Description:

When accessing a single user's profile the API returns far more data than necessary. Full personal details including address, phone, company and website are exposed in a single response.

Data Exposed:

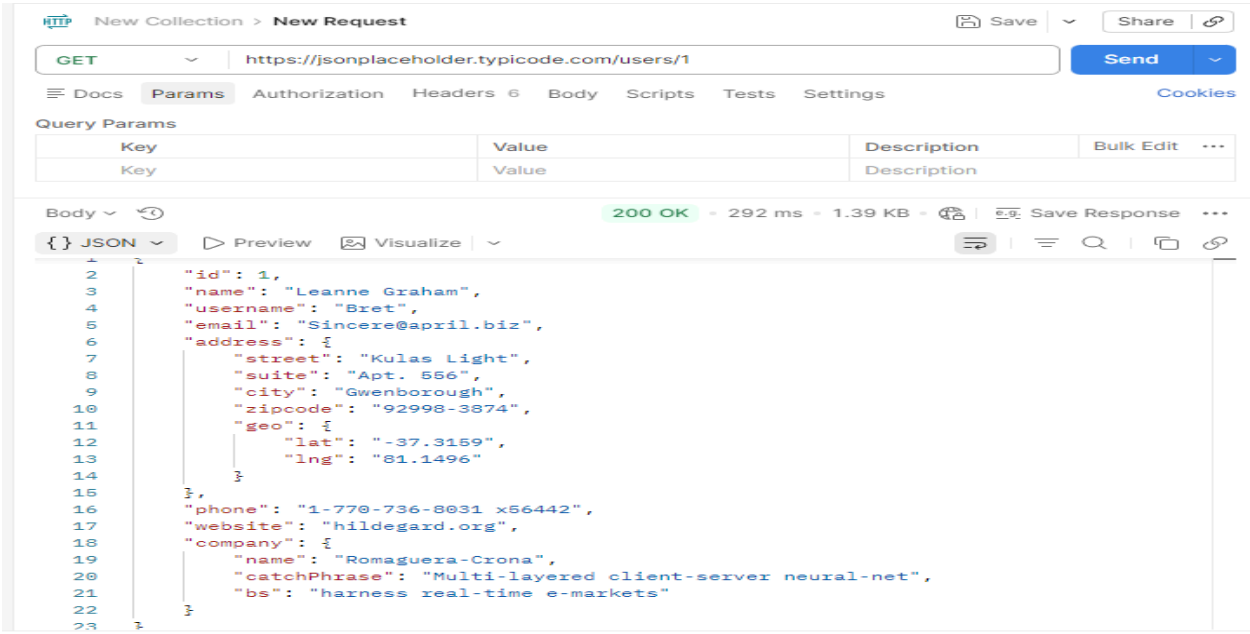
- Full home address with street, city, zipcode
- Geographic coordinates (latitude, longitude)
- Personal phone number
- Company name and business details

Business Impact:

Exposing excessive data increases the risk of privacy breaches. Attackers can use location data and personal details to target individuals with social engineering attacks.

Remediation:

Apply the principle of least privilege. API responses should only return data that is absolutely necessary for the requesting application.Return only name and email for basic user lookups.



3. Unauthorized Access to All Posts

Risk Level: 🟡 MEDIUM

Endpoint Tested:**GET https://jsonplaceholder.typicode.com/posts**

Description:

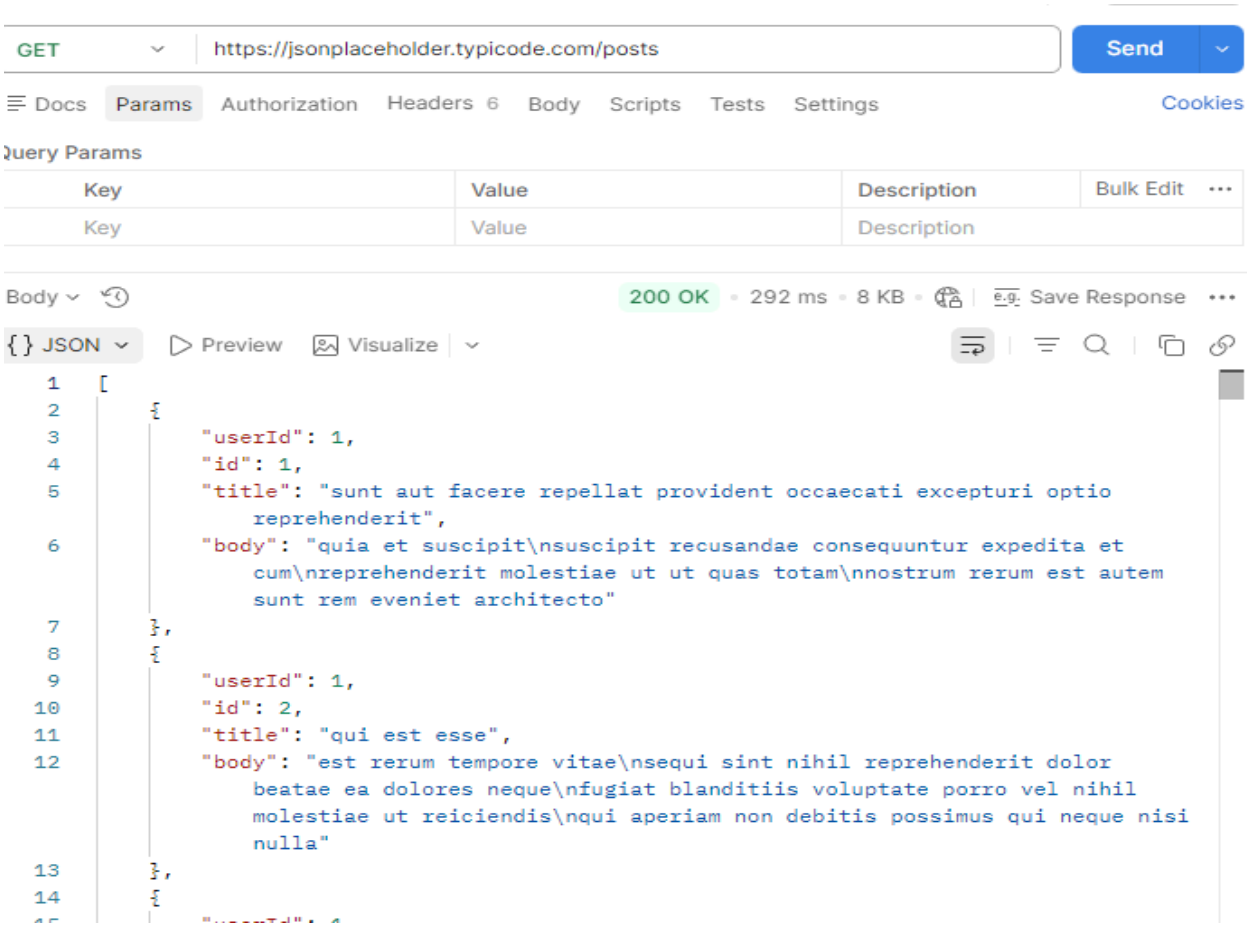
The API returns all 100 posts from all users without any authorization check. Any user can access posts belonging to other users without any permission or authentication.

Business Impact:

In a real application this would allow attackers to read private posts, messages or content belonging to other users. This violates user privacy and data protection regulations.

Remediation:

Implement proper authorization checks. Users should only be able to access their own posts.Add user session validation before returning any post data.



4. Missing Rate Limiting

Risk Level: 🟡 MEDIUM

Endpoint Tested:**GET https://jsonplaceholder.typicode.com/users**
(Multiple rapid requests)

Description:
The API does not implement any rate limiting. Multiple rapid requests were sent to the same endpoint and the API responded successfully every single time without any restriction or blocking.

Business Impact:
Without rate limiting attackers can:

- Send thousands of requests per second
- Crash the server with a DDoS attack
- Scrape all user data very quickly
- Overload the database and cause downtime

Remediation:
Implement rate limiting on all API endpoints.Allow maximum 100 requests per minute per IP.Return HTTP 429 "Too Many Requests" error when limit is exceeded.

Security Recommendations & Remediation Steps

1. Implement API Authentication
Priority: 🔴 **Immediate**

All API endpoints must require authentication before returning any data.

Recommended Solutions:

- - Use API Keys for basic authentication
- - Use JWT (JSON Web Tokens) for user sessions
- - Use OAuth 2.0 for third party integrations
- - Reject all requests without valid credentials
- - Return HTTP 401 Unauthorized for invalid tokens

2. Reduce Data Exposure
Priority: 🔴 **Immediate**

API responses must only return data that is absolutely necessary.

Recommended Solutions:

- Never return sensitive fields like address, phone or location in basic API responses
- Create separate endpoints for detailed data
- Apply field filtering based on user role
- Remove geographic coordinates from responses
- Follow principle of least privilege always

3. Implement Proper Authorization
Priority: 🟡 **High**

Users must only access their own data.

Recommended Solutions:

- Validate user session before every request
- Check if requesting user owns the resource
- Return HTTP 403 Forbidden for unauthorized access
- Never expose other users data in responses
- Implement role based access control (RBAC)

Conclusion

Summary:

This API Security Risk Analysis was conducted on the JSONPlaceholder public test API using Postman as part of the Future Interns Cyber Security Internship Program.
A total of 4 security vulnerabilities were identified during the assessment:

- 🔴 High Risk : 2 vulnerabilities
- 🟡 Medium Risk : 2 vulnerabilities
- 🟢 Low Risk : 0 vulnerabilities

Business Impact

If these vulnerabilities existed in a real production API they could result in:

- Mass data theft of all user personal information
- Identity theft and targeted phishing attacks
- Privacy regulation violations (GDPR, IT Act)
- Server downtime due to DDoS attacks
- Loss of user trust and company reputation
- Heavy financial and legal penalties

Final Recommendation

The API requires immediate implementation of:

- Authentication on all endpoints
- Proper authorization checks
- Data minimization in responses
- Rate limiting on all endpoints

Regular API security audits should be conducted every 3 months to ensure continued protection against new and emerging threats.

Report Prepared By:

Name : **Aditya Goud**
CIN ID **: FIT/APR26/CS7516**
Program : Cyber Security Internship
Company : **Future Interns**
API Tested: JSONPlaceholder
Tool Used : Postman
Date : April 2026